



— AXE B · LE PROTOCOLE KERBEROS

Le serveur le plus **anodin** de votre parc

Trois cases à cocher, et la délégation Kerberos en a fait un passe-partout du domaine — ce pouvoir que vous avez accordé sans le savoir.

Demandez à votre équipe quels serveurs sont critiques chez vous. On vous citera les contrôleurs de domaine, la base RH, le serveur de sauvegarde. Personne ne mentionnera ce vieux serveur d'application que plus personne ne regarde. Et c'est peut-être lui qui, en ce moment, garde en mémoire le laissez-passer d'un administrateur.

■ L'IDÉE REÇUE

« Ce serveur n'héberge pas de données sensibles — il n'est pas critique. »

En réalité — un serveur configuré en délégation Kerberos non contrainte conserve en mémoire le **laissez-passer maître** de chaque compte qui s'y connecte. Sa criticité ne tient pas à ce qu'il *stocke*, mais à ce qu'il *accumule*.

= DC

Le serveur qui valait un contrôleur de domaine

En délégation non contrainte, un serveur ordinaire accumule les mêmes laissez-passer qu'un contrôleur de domaine. En matière de risque, il est son égal — et doit être traité comme tel.

AU SOMMAIRE DE CETTE FICHE

1

Le déclic

L'idée reçue, l'analogie du concierge, l'impact métier.

2

Le mécanisme

Le double saut, les trois options, le TGT mis en cache.

3

La salle des machines

Vérifier, comprendre l'attaque, corriger et détecter.

1

NIVEAU 1 — POUR COMPRENDRE

Le déclic

Imaginez la scène. Vous demandez à votre équipe de lister les serveurs critiques du parc. Les réponses tombent vite : les contrôleurs de domaine, la base RH, le serveur de sauvegarde. Tout le monde est d'accord. Et le vieux serveur d'application dans son coin, celui que personne n'a touché depuis trois ans ? Il ne vient à l'esprit de personne. Après tout, il n'héberge aucune donnée sensible.

C'est exactement là que se cache le malentendu. Pour comprendre, prenons une image. Vous séjournez dans un hôtel et vous confiez une mission au concierge : aller chercher votre voiture au parking. Pour cela, vous lui donnez une autorisation. Deux façons de le faire.

La première : une note précise — « le concierge peut récupérer la voiture, et rien d'autre ». La seconde : vous lui remettez un blanc-seing, une autorisation pré-signée, valable pour *n'importe*

quelle démarche, partout, en votre nom. Et ce blanc-seing, le concierge le range dans un tiroir, à toutes fins utiles.

La note précise, c'est la **délégation contrainte**. Le blanc-seing rangé dans le tiroir, c'est la **délégation non contrainte** — et le tiroir, c'est la mémoire du serveur. Quiconque ouvre ce tiroir n'emprunte pas un objet : il devient vous.

Dans Active Directory, ce blanc-seing porte un nom : le **TGT**, le laissez-passer maître qu'un compte reçoit en ouvrant sa session. Un serveur en délégation non contrainte garde en mémoire le TGT de chaque compte qui s'y connecte. Et l'origine de tout cela est presque toujours la même : un éditeur de logiciel qui, dans son guide d'installation, écrivait « cochez cette case pour que l'application accède à la base ». La case fut cochée. L'application marcha. Et tout le monde oubli.

« La criticité d'un serveur ne se mesure pas à ce qu'il stocke, mais à ce qu'il laisse passer. »

POURQUOI ÇA COMPTE — L'IMPACT MÉTIER

Nous jugeons d'instinct la criticité d'un serveur à la sensibilité des données qu'il contient. La délégation casse cette intuition. Un serveur parfaitement vide de données sensibles peut devenir une cible de premier ordre, uniquement à cause de ce qui *transite* par lui. Le jour où un compte à privilèges s'y connecte — un administrateur en pleine maintenance, un compte de service de sauvegarde, ou pire, un contrôleur de domaine qu'on aura forcé à le faire — son laissez-passer maître se retrouve dans la mémoire de ce serveur oublié. La suite de cette fiche montre comment un attaquant le récupère, et comment lui retirer ce cadeau.

2

NIVEAU 2 — LE FONCTIONNEMENT RÉEL

Le mécanisme

Au départ, la délégation répond à un vrai besoin technique : le **double saut**. Vous ouvrez une application web ; pour afficher vos données, ce serveur web doit lui-même interroger une base de données — et cette base doit savoir que la demande vient bien de *vous*, pas du serveur web. La délégation est le mécanisme qui permet au premier service de « porter » votre identité jusqu'au second.

Kerberos manipule pour cela deux sortes de tickets : le **TGT**, le laissez-passer maître obtenu à l'ouverture de session, qui sert à demander tous les autres ; et le **ticket de service**, valable pour un seul service précis. Normalement, un service ne reçoit jamais que des tickets de service le concernant. La délégation, elle, peut lui confier bien davantage. Tout se règle dans un seul onglet — « Délégation » — des propriétés du compte, qui offre trois choix.



Toute la bascule se joue à l'option 2. Lorsqu'un utilisateur s'authentifie sur un serveur en délégation non contrainte, le KDC glisse une **copie de son TGT** dans le ticket de service remis au serveur, qui la met en cache en mémoire. Dès cet instant, le serveur peut rejouer ce TGT et obtenir des tickets vers *n'importe quel* service, au nom de l'utilisateur. Détail décisif : les contrôleurs de domaine sont, eux, configurés en délégation non contrainte par défaut. Un serveur non contraint malveillant n'est donc rien d'autre qu'un endroit où s'empilent les laissez-passer maîtres.



Schéma 1 — La délégation non contrainte : où le laissez-passer maître est confié, puis mis en cache.

SOUS L'ÉCORCE

« D'accord, mais aucun administrateur de domaine ne se connecte jamais sur mon vieux serveur d'application. » — C'est sans doute vrai, et c'est sans importance. L'attaquant n'attend pas qu'une victime se présente : il la **convoque**. À l'aide d'une technique de coercition, il force la machine de son choix — y compris un contrôleur de domaine — à s'authentifier sur le serveur non contraint, à la demande. Le laissez-passer maître de la victime atterrit alors en mémoire au moment voulu. L'accumulation passive devient une récolte active : c'est ce qui transforme une mauvaise configuration dormante en compromission immédiate.

3

NIVEAU 3 — SUR LE TERRAIN

La salle des machines

Trois gestes, toujours dans le même ordre : **vérifier** où se cache la délégation, **comprendre** ce qu'un attaquant en ferait, puis **corriger et détecter**.

1 Vérifier

Commençons par le diagnostic. Cette commande liste tous les ordinateurs du domaine porteurs de l'indicateur de délégation non contrainte — à exécuter depuis un poste disposant du module Active Directory (RSAT).

```
LA COMMANDE DU JOUR — INVENTORIER LA DÉLÉGATION NON CONTRAINTE

PS C:\> Get-ADComputer -Filter {TrustedForDelegation -eq $true} `
>> -Properties TrustedForDelegation | Select-Object Name, DistinguishedName
```

Mot à mot. `-Filter` ne retient que les objets dont la propriété `TrustedForDelegation` vaut « vrai ». Point de vigilance : vos contrôleurs de domaine apparaîtront — c'est normal, ils sont non contraints par nature. **Tout autre serveur dans la liste est l'anomalie à investiguer.**

```
Administrateur : Windows PowerShell

PS C:\> Get-ADComputer -Filter {TrustedForDelegation -eq $true} `
>> -Properties TrustedForDelegation | Select Name

Name                DistinguishedName
----                -
DC01                 CN=DC01,OU=Domain Controllers,DC=adcompagn ...
DC02                 CN=DC02,OU=Domain Controllers,DC=adcompagn ...
SRV-APP01            CN=SRV-APP01,CN=Computers,DC=adcompagn ...
PS C:\>
```

! L'anomalie

DC01 et DC02 sont des contrôleurs de domaine : la délégation y est normale.

SRV-APP01 ne l'est pas.

Capture simulée — l'inventaire sur `adcompagnon.lab` : deux DC légitimes, un serveur de trop.

2 Comprendre l'attaque

La délégation non contrainte n'est pas une faille en soi : c'est un **accélérateur**. Voici la chaîne, telle qu'un attaquant la déroule — du repérage à la chute du domaine.

■ CE QU'UN ATTAQUANT EN FAIT

1 Le repérage

Il énumère les serveurs non contraints — un outil de cartographie comme **BloodHound** les signale d'emblée. Il en compromet un, ou en trouve un déjà à sa portée. Aucun n'a besoin d'être « critique ».

2 L'embuscade

Sur ce serveur, il lance un moniteur de tickets — `Rubeus.exe monitor` — qui guette l'arrivée de tout TGT en mémoire et l'extrait à la volée.

3 La convocation

Il force un contrôleur de domaine à s'authentifier sur le serveur, par une technique de coercition — le « bug de l'imprimante » (MS-RPRN) ou PetitPotam (MS-EFSR). Le contrôleur obéit : son TGT atterrit dans la mémoire du serveur.

4 Le sacre

Rubeus capture le TGT de `DC01$`. Avec le laissez-passer maître d'un contrôleur de domaine, l'attaquant lance un **DCSync** : il se fait répliquer la totalité des secrets du domaine, dont la clé `krbtgt`. Le domaine est tombé.

À chaque maillon, la délégation non contrainte est le point de départ. **Retirez-la, et la chaîne n'a plus d'amorce.**

3 Corriger et détecter

La correction tient en trois gestes. Le premier protège vos comptes les plus précieux ; le deuxième tarit la source ; le troisième complique la convocation.

1 Blinder les comptes à privilèges

Cochez « Le compte est sensible et ne peut pas être délégué » sur vos comptes d'administration ; mieux encore, placez-les dans le groupe « Utilisateurs protégés ». Un TGT non déléguable ne peut plus être rejoué, même capturé.

● ● ● PROTÉGER UN COMPTE D'ADMINISTRATION

```
PS C:\> Set-ADUser -Identity 'a.bernard' -AccountNotDelegated $true
PS C:\> Add-ADGroupMember -Identity 'Utilisateurs protégés' -Members 'a.bernard'
```

2 Éradiquer la délégation non contrainte

Retirez l'indicateur des serveurs concernés. Si l'application a réellement besoin de déléguer, remplacez-le par de la délégation **contrainte**, limitée aux seuls services nécessaires — ou par la délégation basée sur les ressources (RBCD).

● ● ● RETIRER LA DÉLÉGATION NON CONTRAINTE

```
PS C:\> Set-ADComputer -Identity 'SRV-APP01' -TrustedForDelegation $false
```

3 Réduire la surface de coercition

L'attaque a besoin de *forcer* une authentification. Désactivez le service Spouleur d'impression là où il est inutile, appliquez les correctifs récents, et restreignez les flux RPC entrants vers vos contrôleurs de domaine.

Détecter — les bons événements

Surveillez trois événements sur vos contrôleurs de domaine et vos serveurs sensibles.

ID 4742 « Un compte d'ordinateur a été modifié ». L'activation de l'indicateur de délégation sur un serveur, hors fenêtre de changement documentée, est une alerte — qu'il s'agisse d'une erreur ou d'un attaquant qui pose une porte dérobée.

ID 4738 « Un compte d'utilisateur a été modifié ». Un **compte utilisateur** qui se voit attribuer un indicateur de délégation est presque toujours anormal et mérite une investigation immédiate.

ID 5145 « Un objet de partage réseau a été vérifié ». Des accès répétés, depuis un contrôleur de domaine, aux tubes nommés `\spoolss` ou `\efsrpc` d'un autre hôte trahissent une tentative de coercition.

Pour une **chasse proactive**, ce filtre LDAP attrape d'un coup tout objet — ordinateur ou utilisateur — porteur du bit de délégation non contrainte :

● ● ● CHASSE — LE BIT DE DÉLÉGATION, ORDINATEURS ET COMPTES

```
PS C:\> Get-ADObject -LDAPFilter '(userAccountControl:1.2.840.113556.1.4.803:=524288)' `
>> -Properties userAccountControl | Select-Object Name, ObjectClass
```

OBSERVATEUR D'ÉVÉNEMENTS — JOURNAL SÉCURITÉ

Event ID 4742

Tâche : Gestion des comptes d'ordinateurs

Compte d'ordinateur : ADCOMPAGNON\SRV-APP01\$

Modifié par : ADCOMPAGNON\a.bernard

Indicateurs modifiés: **TrustedForDelegation = Activé ← délégation non contrainte****! Activation de la délégation hors changement planifié — à corrélérer avec la fenêtre de maintenance.**

■ VU SUR LE TERRAIN

Lors de l'audit d'un groupe de taille moyenne, l'équipe d'attaque cherche un point d'appui. Elle ne vise pas les contrôleurs de domaine ni la base RH — trop surveillés. Elle lance une cartographie de l'annuaire, et un serveur s'allume aussitôt en rouge : un vieux serveur de supervision, configuré en délégation non contrainte des années plus tôt, en suivant à la lettre le guide d'installation d'un éditeur. En moins d'une heure, sans avoir touché le moindre serveur classé « critique », l'équipe coercait un contrôleur de domaine, capturait son laissez-passer maître et obtenait les droits d'administration du domaine. Le correctif tenait, lui, en une case à décocher.

■ LE COIN DU DÉCIDEUR

La criticité d'un serveur ne se confond pas avec la sensibilité de ses données. Elle se mesure à ses **relations de confiance**. Un serveur en délégation non contrainte appartient, en matière de risque, au même niveau que vos contrôleurs de domaine — le **Tier 0** — et doit être classé, surveillé et protégé comme tel. La bonne question pour votre équipe n'est pas « ce serveur est-il sensible ? », mais « **avons-nous l'inventaire complet de nos délégations ?** ». Inscrivez une règle simple dans votre socle : la délégation non contrainte est interdite par défaut ; la délégation contrainte s'accorde au cas par cas, et se documente.

■ L'ÉNIGME DU COMPAGNON — N°02

Sur `adcompagnon.lab`, un compte de service **svc-web** est configuré en délégation *contrainte* — l'option encadrée — vers un seul service : `HTTP/SRV-FILE01`. L'administrateur est rassuré : « svc-web ne pourra jamais atteindre que le service web de ce serveur, c'est cloisonné ». **Pourquoi se trompe-t-il, et que peut réellement faire un attaquant qui contrôle svc-web ?**

LA RÉPONSE DU COMPAGNON

Parce que la contrainte porte sur l'**hôte**, pas sur le **service**. Quand svc-web demande un ticket par S4U2Proxy, le KDC le délivre pour SRV-FILE01 — mais la classe de service inscrite dans le nom (`HTTP`) n'est pas réellement verrouillée : l'attaquant peut réclamer à la place `CIFS/SRV-FILE01` (partages de fichiers) ou `HOST/SRV-FILE01` (exécution à distance). La « contrainte » n'a jamais limité que la machine de destination. Et si la sous-option « tout protocole d'authentification » est cochée, il le fait au nom de *n'importe qui* — un administrateur de domaine compris. Délégation contrainte contraint le *où*, jamais le *quoi*.

■ LE GLOSSAIRE

Kerberos — le protocole d'authentification d'Active Directory ; il délivre des tickets plutôt que de transmettre les mots de passe.

TGT — le « laissez-passer maître » obtenu à l'ouverture de session ; il sert à demander tous les autres tickets.

Ticket de service — un laissez-passer valable pour un seul service précis.

KDC — le composant du contrôleur de domaine qui délivre les tickets Kerberos.

SPN — le nom qui identifie un service sur le réseau ; sa première partie est la classe de service.

Double saut — le besoin, pour un service, de se présenter à un second service au nom de l'utilisateur d'origine.

Délégation non contrainte — réglage confiant à un serveur le TGT de l'utilisateur, utilisable vers tout service.

Délégation contrainte — variante limitant la délégation à une liste de services désignés.

Coercition — technique forçant une machine à s'authentifier vers une cible choisie par l'attaquant.

DCSync — abus de la réplication AD pour se faire livrer les secrets du domaine, dont la clé `krbtgt`.

Utilisateurs protégés — groupe dont les membres ne peuvent être délégués.

Tier 0 — le niveau des actifs qui contrôlent l'annuaire ; le périmètre le plus protégé.

DANS LE PROCHAIN NUMÉRO



N°03 — Les permissions de l'annuaire : le trousseau de clés que personne n'a inventorié

Comment un simple droit d'écriture, oublié sur un objet, rejoue à lui seul tout ce que vous croyiez verrouillé.